COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.4 · On-path Attacks

Mestre CyberSec · **Aula 2.4 — On-path Attacks** (5:30) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: On-path (antigo man-in-the-middle): atacante fica no MEIO da comunicação e INTERCEPTA ou ALTERA o tráfego. ARP spoofing (mentira no MAC table local — o tráfego passa pelo atacante); evil twin AP; DNS poisoning. Defesa: TLS em tudo (o S importa), VPN em rede pública, ARP inspectio

💡 Highlights que a prova CompTIA cobra

- On-path (antes MITM): intercepta e/ou altera comunicação
- ARP spoofing: mentira o MAC — redireciona tráfego ao atacante
- Defesa nº1: HTTPS em tudo (o TLS autêntica o endpoint)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'traffic intercepted between two parties' = on-path/MITM

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.4 — On-path Attacks)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Ataque On-Path (antigo Man-in-the-Middle) (MITM)

Ataque em que o adversário se posiciona ENTRE duas partes que se comunicam para interceptar, ler ou alterar o tráfego sem que nenhum dos lados perceba. Antigamente chamado de Man-in-the-Middle (MITM).

⚠️ ***Armadilha CompTIA:*** *Qualquer questão dizendo 'traffic intercepted between two parties' ou 'attacker sits in the middle of communication' = on-path. CompTIA atualizou o nome: MITM e on-path são o mesmo ataque.*

• Falsificação de ARP (ARP Poisoning)

Envio de respostas ARP falsificadas na rede local para associar o endereço MAC do atacante a um IP legítimo (como o gateway padrão), redirecionando o tráfego pela máquina do atacante. Funciona porque o ARP não tem autenticação.

⚠️ ***Armadilha CompTIA:*** *ARP spoofing é o MECANISMO técnico mais cobrado para viabilizar um ataque on-path na LAN. Gatilho: 'MAC table', 'gateway traffic redirected', 'local network interception'. Lembre: ARP não autentica nada — qualquer um pode responder.*

• Gêmeo Maligno (Ponto de Acesso Falso) (AP)

Ponto de acesso sem fio falso configurado para imitar um legítimo (SSID igual ou parecido), enganando usuários para que se conectem — permitindo ao atacante interceptar todo o tráfego. É a forma sem fio do ataque on-path.

⚠️ ***Armadilha CompTIA:*** *Não confunda: Evil Twin = AP falso com SSID legítimo (interceptação); Rogue AP = AP não autorizado plugado na rede corporativa. Gatilho: 'fake Wi-Fi hotspot', 'users connected to malicious access point'.*

• Envenenamento de DNS (DNS Cache Poisoning)

Injeção de registros DNS falsos no cache de um resolvedor, fazendo nomes de domínio legítimos resolverem para IPs controlados pelo atacante, redirecionando usuários silenciosamente para sites maliciosos.

⚠️ ***Armadilha CompTIA:*** *Se a questão fala em 'users redirected to fake site despite typing correct URL', pense em DNS poisoning/spoofing. Defesas cobradas: DNSSEC (autentica as respostas) e validação de respostas DNS.*

• Segurança da Camada de Transporte (TLS)

Protocolo criptográfico que cifra o tráfego e autentica o endpoint do servidor via certificados digitais, derrotando atacantes on-path mesmo quando eles enxergam o tráfego. É o 'S' do HTTPS.

⚠️ ***Armadilha CompTIA:*** *Defesa nº1 contra on-path segundo Messer: 'TLS em tudo — o S importa'. A questão-chave: interceptar não basta, pois com TLS o atacante vê só dados cifrados. Um alerta de certificado inválido no navegador pode indicar um ataque on-path em andamento!*

• Rede Privada Virtual (VPN)

Cria um túnel criptografado entre o cliente e um endpoint confiável, protegendo todo o tráfego contra interceptação em redes não confiáveis como Wi-Fi público — defesa primária contra ataques on-path.

⚠️ ***Armadilha CompTIA:*** *Gatilho clássico: 'user on public Wi-Fi / coffee shop / hotel network, how to protect traffic?' = VPN (túnel criptografado). A VPN protege mesmo se o usuário cair num Evil Twin.*

• Inspeção Dinâmica de ARP (DAI)

Recurso de segurança em switches que valida pacotes ARP contra uma tabela de vínculos confiáveis (geralmente construída pelo DHCP snooping) e descarta respostas ARP falsificadas, bloqueando diretamente o ARP spoofing na LAN.

⚠️ ***Armadilha CompTIA:*** *Se a pergunta pedir como PREVENIR ARP spoofing/poisoning em switches = DAI. Memorize a dupla: DHCP snooping constrói a tabela → DAI a usa para validar o ARP. Costuma cair junto.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Ataque do Aniversário e Colisão de Hash (Birthday Attack & Hash Collisions)

🏠 **Analogia Intuitiva:** Em uma sala com apenas 23 pessoas, a probabilidade matemática de que pelo menos duas façam aniversário no mesmíssimo dia do ano já é superior a 50%. O segredo é que você não está procurando alguém que faça aniversário no SEU dia específico; você só quer achar QUALQUER par de pessoas que coincida. Em um ataque de aniversário, o fraudador cria dois documentos totalmente diferentes (um contrato inocente e outro transferindo o patrimônio da vítima para ele) e faz pequenas alterações invisíveis nos textos (adicionando espaços ou pontuação) até que ambos gerem exatamente o mesmo código de hash. Ele faz a vítima assinar digitalmente o documento bom, mas cola a assinatura válida no documento fraudulento.

🔍 **Causa Raiz / Por que foi criado:** O paradoxo do aniversário reduz drasticamente o número de tentativas necessárias para encontrar duas entradas que produzam a mesma saída de hash (de 2^n para 2^(n/2)). Algoritmos de hash antigos com saídas curtas ou fraquezas matemáticas (como MD5 de 128 bits e SHA-1 de 160 bits) tornam viável gerar colisões de hash na prática.

🛡️ **Visão do Auditor de GRC:** Proibir expressamente em políticas de conformidade (PCI-DSS, ISO 27001, FIPS 140-3) o uso de algoritmos obsoletos como MD5 e SHA-1; homologar apenas funções hash modernas e resistentes a colisões como SHA-256 (família SHA-2) e SHA-3.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'attacker generates two different inputs that produce the exact same cryptographic hash value' -> Hash Collision / Birthday Attack. Pegadinha: A banca quase sempre cita MD5 ou SHA-1 como o exemplo de algoritmo suscetível.

📌 Downgrade Attack e SSL Stripping

🏠 **Analogia Intuitiva:** O Downgrade Attack é como você chegar na embaixada falando inglês moderno fluente com um sistema seguro e o guarda corrupto no portão falar: 'O tradutor moderno está fora do ar, você é obrigado a falar no dialeto antigo e fraco do século XV', permitindo que qualquer pessoa escutando no corredor decifre sua mensagem. O SSL Stripping é o carteiro interceptar a carta que você mandou lacrada em um cofre com cadeado (HTTPS), arrancar a carta de dentro do cofre, colocá-la em um envelope de papel transparente comum (HTTP) e entregar na agência do banco, permitindo que qualquer pessoa no caminho leia suas senhas em texto claro.

🔍 **Causa Raiz / Por que foi criado:** Para manter compatibilidade com navegadores ou sistemas legados antigos, servidores aceitavam negociar versões criptográficas antiquadas (como SSL 3.0, TLS 1.0 ou cifras export). No SSL stripping, um atacante on-path intercepta a requisição HTTP inicial e impede o redirecionamento automático para HTTPS.

🛡️ **Visão do Auditor de GRC:** Desativar permanentemente protocolos obsoletos no servidor web (bloquear SSLv2, SSLv3, TLS 1.0, TLS 1.1) permitindo apenas TLS 1.2 e TLS 1.3; e configurar o cabeçalho HSTS (HTTP Strict Transport Security) com a diretiva `includeSubDomains; preload` para forçar os navegadores a nunca aceitarem conexões HTTP puras.

> ⚠️ **Como cai na Prova CompTIA:** Trigger: 'attacker forces a client and server to abandon modern encryption and communicate using an older, insecure protocol' -> Downgrade Attack. Trigger: 'attacker intercepts web traffic and strips HTTPS encryption, downgrading session to plain HTTP' -> SSL Stripping (Mitigação: HSTS).

📌 Replay Attacks e Proteções com Nonce & Timestamps

🏠 **Analogia Intuitiva:** Um ataque de repetição (Replay) é como você gravar em fita cassete o som do seu chefe destrancando o cofre eletrônico por comando de voz dizendo: 'Abre cofre, senha Alfa'. À noite, quando não há ninguém, o ladrão entra na sala vazia, aperta o 'play' na fita cassete e o cofre abre, mesmo sem o ladrão saber como a senha foi criada. O Nonce (número de uso único) é o cofre responder antes de abrir: 'Diga a senha seguida do número aleatório único que acabou de aparecer no visor agora: 7392'. Como o número 7392 só vale uma única vez e expira em 5 segundos (timestamp), a gravação de ontem na fita cassete se torna inútil e o cofre rejeita a tentativa.

🔍 **Causa Raiz / Por que foi criado:** Protocolos de autenticação que não incluem dados aleatórios efêmeros e carimbos de tempo transmitem credenciais ou hashes estáticos (ex: NTLM). O invasor captura os pacotes na rede e os retransmite sem precisar decifrar a senha original.

🛡️ **Visão do Auditor de GRC:** Auditar a desativação de protocolos legados suscetíveis a replay (como NTLM e LM) em favor de Kerberos (que exige sincronização de relógio via NTP e tíquetes com timestamps); e exigir uso de tokens criptográficos descartáveis com Nonce em APIs e transações bancárias.

> ⚠️ **Como cai na Prova CompTIA:** Trigger: 'attacker captures legitimate authentication packets on the wire and retransmits them later to gain unauthorized access' -> Replay Attack. Mitigações essenciais: Nonce (Number used once) e Timestamps.

📌 Texto Claro Conhecido vs. Somente Texto Cifrado (Known Plaintext vs. Ciphertext-Only)

🏠 **Analogia Intuitiva:** Somente Texto Cifrado (Ciphertext-Only) é o detetive encontrar um pergaminho com símbolos alienígenas indecifráveis em um cofre, sem ter a menor pista de que idioma ou assunto está escrito ali dentro. Texto Claro Conhecido (Known Plaintext) é o espião interceptar o mesmo pergaminho cifrado, mas já saber com certeza absoluta que a primeira frase do documento sempre começa com 'Ao Presidente da República:' porque todas as cartas oficiais daquele órgão começam com esse cabeçalho idêntico. Ao comparar a frase conhecida com os símbolos cifrados correspondentes, o espião deduz o segredo da cifra.

🔍 **Causa Raiz / Por que foi criado:** Protocolos ou arquivos que utilizam cifras fracas ou modos de operação inadequados (como AES em modo ECB - Electronic Codebook) cifram blocos de dados idênticos sempre no mesmo texto cifrado correspondente. Conhecer trechos fixos de cabeçalhos de arquivos permite deduzir a chave criptográfica.

🛡️ **Visão do Auditor de GRC:** Proibir o uso de modos de operação determinísticos (proibir ECB) em políticas de desenvolvimento seguro (OWASP ASVS); exigir cifras em modos autenticados e probabilísticos (como AES-GCM ou CBC com Vetor de Inicialização / IV criptograficamente aleatório e imprevisível).

> ⚠️ **Como cai na Prova CompTIA:** Trigger: 'analyst has access to both an encrypted message and its corresponding decrypted original plaintext for portions of the transmission' -> Known Plaintext Attack. Se o atacante possuir estritamente apenas a mensagem criptografada sem nenhum texto claro: Ciphertext-Only Attack.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Atacante encontra duas mensagens de texto totalmente diferentes que geram exatamente o mesmo valor de hash criptográfico	**Colisão de Hash / Ataque do Aniversário (Birthday Attack)**
Invasor força a comunicação a abandonar cifras seguras e negociar uma versão de protocolo antiga e cheia de falhas	**Downgrade Attack**
Cabeçalho web de segurança que instrui o navegador a comunicar-se exclusivamente através de conexões HTTPS criptografadas	**HSTS (HTTP Strict Transport Security)**
Invasor captura pacotes válidos de autenticação na rede e os reenvia mais tarde para se passar pelo usuário sem decifrar a senha	**Ataque de Repetição (Replay Attack)**
Valor numérico aleatório de uso único gerado a cada autenticação para garantir que requisições repetidas sejam rejeitadas	**Nonce (Number Used Once)**
Criptoanalista possui trechos do texto original em claro e seus respectivos blocos cifrados para deduzir a chave de cifragem	**Ataque de Texto Claro Conhecido (Known Plaintext Attack)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista de segurança de um hospital revisa logs de switch e vê inúmeras respostas ARP em que o mesmo endereço MAC afirma ser o gateway padrão e vários servidores de dispositivos médicos. O tráfego entre os servidores e as estações clínicas está sendo redirecionado silenciosamente. Qual recurso do switch o analista deve habilitar para impedir esse ataque específico?

A) Dynamic ARP Inspection

B) DNSSEC

C) Autenticação de porta 802.1X

D) Modo túnel IPsec

QUESTÃO 2 · CENÁRIO DE EXAME

Um vendedor em viagem se conecta a uma rede sem fio chamada Airport_Free_WiFi em um aeroporto. Logo depois, o navegador exibe um aviso de certificado para o site de webmail da empresa, e suspeita-se que credenciais de login foram roubadas. Investigadores encontram um ponto de acesso malicioso transmitindo o mesmo SSID com sinal mais forte. Qual ataque melhor corresponde a esse cenário?

A) Envenenamento de cache DNS

B) VLAN hopping

C) Evil twin

D) ARP spoofing

QUESTÃO 3 · CENÁRIO DE EXAME

Funcionários de um escritório remoto relatam que digitar o nome do portal interno de folha de pagamento resolve para um endereço IP externo que hospeda uma página de login falsa. O cache do resolvedor DNS interno contém uma entrada que não foi criada pelo servidor autoritativo. Qual controle de segurança valida diretamente as respostas DNS para impedir esse tipo de falsificação de registro?

A) Dynamic ARP Inspection

B) DNSSEC

C) WPA3-Enterprise

D) Port security

QUESTÃO 4 · CENÁRIO DE EXAME

Um funcionário remoto precisa acessar compartilhamentos de arquivos corporativos pelo Wi-Fi aberto de uma cafeteria. A empresa deseja proteger todo o tráfego contra interceptação on-path, incluindo protocolos que não usam criptografia nativamente. Qual solução a equipe de segurança deve exigir?

A) Ocultar o SSID no notebook do funcionário

B) Configurar entradas ARP estáticas para o servidor corporativo

C) Usar somente DNS over HTTPS

D) Uma VPN full-tunnel com autenticação baseada em certificado

QUESTÃO 5 · CENÁRIO DE EXAME

Uma aplicação web está configurada para usar HTTPS, mas usuários em uma rede não confiável às vezes são redirecionados da requisição HTTP inicial para uma página HTTP controlada pelo atacante antes de chegar à página de login. Qual controle previne melhor esse ataque on-path de SSL stripping em visitas futuras?

A) HTTP Strict Transport Security

B) Dynamic ARP Inspection

C) DNSSEC

D) Controle de acesso à rede

QUESTÃO 6 · CENÁRIO DE EXAME

Em uma LAN de campus, vários usuários de repente recebem configuração IP com um endereço de gateway padrão que pertence a um notebook não autorizado. O tráfego deles então é roteado por esse notebook. Qual recurso do switch impede mais diretamente que servidores DHCP maliciosos atribuam configurações de gateway maliciosas?

A) Dynamic ARP Inspection

B) DHCP snooping

C) Private VLANs

D) Spanning Tree Protocol

QUESTÃO 7 · CENÁRIO DE EXAME

Um administrador planeja habilitar Dynamic ARP Inspection em switches de acesso para impedir ARP spoofing. Os switches atualmente não têm recursos de segurança de Camada 2 configurados. Qual configuração normalmente é necessária para que o DAI valide pacotes ARP com base em associações confiáveis?

A) Filtragem de rotas BGP

B) Inspeção TLS

C) DHCP snooping

D) Autenticação RADIUS para todos os usuários

QUESTÃO 8 · CENÁRIO DE EXAME

Um testador de penetração na mesma VLAN que um alvo usa respostas ARP forjadas para fazer o alvo acreditar que o endereço MAC do testador é o gateway. O testador então encaminha pacotes para o gateway real enquanto os captura. Qual termo descreve melhor esse ataque?

A) Ataque de negação de serviço

B) Injeção SQL

C) Cross-site scripting

D) Ataque on-path

QUESTÃO 9 · CENÁRIO DE EXAME

Notebooks corporativos estão configurados para entrar automaticamente em qualquer rede sem fio chamada CompanyGuest. Um atacante monta um AP malicioso com esse nome perto do saguão de um hotel. Qual mudança de configuração reduz mais diretamente o risco de os notebooks se conectarem ao AP malicioso?

A) Desabilitar conexão automática a SSIDs abertos ou não confiáveis e exigir perfis gerenciados

B) Habilitar port security em todos os switches de acesso

C) Substituir DNSSEC por DNS over HTTP

D) Ativar Spanning Tree Protocol nos controladores sem fio

QUESTÃO 10 · CENÁRIO DE EXAME

Um funcionário ignora um aviso do navegador sobre um certificado não confiável ao usar Wi-Fi público. Mais tarde, um analista de segurança descobre que a sessão foi descriptografada por um atacante que apresentou um certificado autoassinado. Qual ação do usuário teria impedido mais diretamente a interceptação?

A) Habilitar filtragem de endereço MAC

B) Parar e não prosseguir quando o aviso de certificado apareceu

C) Ocultar o SSID sem fio

D) Desabilitar o firewall local

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Dynamic ARP Inspection

A Dynamic ARP Inspection valida pacotes ARP em portas não confiáveis do switch usando a tabela de binding do DHCP snooping ou ACLs ARP estáticas. Ela descarta respostas ARP forjadas que associam o IP do gateway ao MAC do atacante, prevenindo o redirecionamento on-path local. DNSSEC protege registros DNS, 802.1X controla acesso à rede, e IPsec não impede envenenamento ARP na LAN.

Questão 2: Alternativa C — Evil twin

Um evil twin é um ponto de acesso malicioso que se passa por um SSID legítimo para atrair clientes. O sinal mais forte e o aviso de certificado no site corporativo são consistentes com o cliente conectando-se ao AP do atacante e sendo interceptado. Envenenamento de cache DNS afeta resolução de nomes, ARP spoofing é camada 2 em uma LAN, e VLAN hopping é um ataque de comutação, não um AP sem fio falso.

Questão 3: Alternativa B — DNSSEC

O DNSSEC fornece assinaturas criptográficas para registros DNS, permitindo que resolvedores validadores detectem respostas forjadas ou alteradas. DAI protege ARP, WPA3-Enterprise protege enlaces sem fio, e port security limita endereços MAC em portas de switch; nenhum valida a autenticidade de registros DNS.

Questão 4: Alternativa D — Uma VPN full-tunnel com autenticação baseada em certificado

Uma VPN full-tunnel criptografa todo o tráfego do endpoint até o gateway corporativo, protegendo até protocolos sem criptografia contra interceptação on-path em Wi-Fi público. Ocultar SSIDs, entradas ARP estáticas e apenas DoH não protegem o tráfego geral. DoH protege somente consultas DNS.

Questão 5: Alternativa A — HTTP Strict Transport Security

O HSTS instrui os navegadores a usar somente HTTPS para um domínio e impede ataques de downgrade de protocolo, como SSL stripping, após a primeira visita confiável. DAI, DNSSEC e NAC tratam de camadas diferentes e não impedem um downgrade de HTTP para HTTPS na camada de aplicação.

Questão 6: Alternativa B — DHCP snooping

O DHCP snooping designa portas confiáveis do switch para servidores DHCP e bloqueia ofertas DHCP de portas não confiáveis, impedindo que servidores DHCP maliciosos atribuam gateway ou DNS maliciosos. DAI protege ARP, private VLANs restringem isolamento de camada 2, e STP previne loops.

Questão 7: Alternativa C — DHCP snooping

O DAI normalmente depende do banco de dados de binding do DHCP snooping para saber quais mapeamentos IP-para-MAC são válidos em cada porta. ACLs ARP estáticas podem ser usadas em alguns projetos, mas o DHCP snooping é o pré-requisito padrão. Filtragem BGP, inspeção TLS e autenticação RADIUS não fornecem bindings para DAI.

Questão 8: Alternativa D — Ataque on-path

Forjar respostas ARP para inserir o atacante entre a vítima e o gateway, e depois encaminhar o tráfego enquanto o captura, é um ataque on-path, frequentemente chamado de man-in-the-middle. Não é primariamente DoS, injeção SQL ou XSS.

Questão 9: Alternativa A — Desabilitar conexão automática a SSIDs abertos ou não confiáveis e exigir perfis gerenciados

Desabilitar conexões automáticas a SSIDs abertos ou não confiáveis e exigir perfis sem fio gerenciados impede que clientes entrem silenciosamente em um evil twin. Port security, DNS over HTTP e STP não impedem a associação de clientes sem fio a um AP malicioso.

Questão 10: Alternativa B — Parar e não prosseguir quando o aviso de certificado apareceu

O TLS protege contra interceptação on-path somente quando o cliente valida o certificado do servidor. Prosseguir após um aviso de certificado não confiável permite que um atacante com certificado autoassinado encerre e leia a sessão TLS. Filtragem MAC, ocultação de SSID e desabilitar o firewall não corrigem a validação de certificado.